

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51 **COURSE NAME:** Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I SOFIA R.V. - 192511055 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

SOFIA RV

Annexure A

Industry Problem-Solving Task

1. A multinational enterprise is deploying IPsec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
- B. Design packet flow with appropriate IPsec modes (transport/tunnel)
- C. Justify protocol selection for different data types
- D. Evaluate performance vs security trade-offs

IPsec Deployment: AH and ESP Configuration

A multinational enterprise wants to secure branch-office communication over the public internet using IPsec. The design must decide where AH is enough, where ESP is required, and which mode (transport or tunnel) fits each traffic type.

A. Traffic classification – AH, ESP, or both

- Branch-to-branch WAN traffic over the internet (site-to-site VPN): needs confidentiality + integrity → ESP (with authentication, i.e. ESP in authenticated-encryption mode such as AES-GCM). AH is not sufficient alone because it does not encrypt payload data.
- Internal routing/control-plane traffic (e.g., OSPF/BGP updates between edge routers) where confidentiality is less critical but tampering must be detected: AH alone can be used, since AH protects the entire IP header (including source/destination) against modification and spoofing.
- Financial transaction data, HR records, and other sensitive application traffic crossing the public internet: ESP with authentication (both encryption and integrity) is mandatory.
- Traffic that must survive NAT devices between branches: ESP is preferred over AH, because AH's header integrity check breaks when NAT rewrites IP addresses; ESP (in tunnel mode with NAT-Traversal/UDP 4500 encapsulation) tolerates NAT.
- Where both origin authentication of the outer IP header and payload confidentiality are simultaneously required by policy (e.g., regulatory mandates), AH and ESP can be combined (AH in transport, ESP in tunnel, or nested tunnels), though in practice most modern deployments simply use ESP with strong authenticated encryption and drop AH, since ESP-auth already covers integrity for the encapsulated packet.

B. Packet flow design – transport vs tunnel mode

- Branch office ↔ branch office over the internet (gateway-to-gateway): Tunnel mode ESP between the two branch security gateways/routers. The entire original IP packet (header + payload) is encrypted and encapsulated inside a new IP header addressed gateway-to-gateway. This hides internal addressing and protects the whole packet.
- Host-to-host traffic within a single trusted branch LAN (e.g., server-to-server inside the same office): Transport mode can be used if IPSec is applied end-to-end, since only the payload needs protection and the original IP header (internal, already trusted) can remain visible.
- Remote/mobile employees connecting to a branch (client-to-gateway VPN): Tunnel mode ESP, because the client's real IP and internal destination address must both be hidden and a new tunnel header assigned by the VPN gateway.
- End-to-end sensitive flows between two specific hosts across different branches where the enterprise wants defense-in-depth: Nested IPSec — Transport-mode ESP between the two end hosts, carried inside Tunnel-mode ESP between the two gateways.

C. Justification of protocol selection

- ESP is chosen wherever confidentiality is a requirement, since AH provides authentication/integrity only and never encrypts data — using AH alone would leave WAN traffic readable to any interceptor on the public internet.
- AH is retained only for scenarios needing strict, whole-packet (including IP header) origin authentication where payload is not sensitive and NAT is not present, e.g., internal routing protocol authentication.
- Tunnel mode is selected for all inter-gateway and remote-access traffic because it hides the internal network topology and lets a single gateway pair protect many internal hosts without configuring IPSec on each endpoint.
- Transport mode is reserved for trusted, low-latency, host-to-host links where header overhead should be minimized and endpoint IP addresses do not need to be hidden.

D. Performance vs security trade-offs

- Tunnel mode adds a full extra IP header (~20 bytes) and NAT-T UDP encapsulation overhead, increasing bandwidth use and fragmentation risk versus transport mode — an acceptable cost for the extra confidentiality/anonymity of internal addressing.
- ESP with strong ciphers (AES-256-GCM) costs more CPU on gateways than AH-only authentication, but modern routers/firewalls offload AES in hardware (AES-NI), so the throughput penalty is minor relative to the confidentiality gained.
- Combining AH + ESP (belt-and-braces) roughly doubles per-packet processing and header overhead; the enterprise should reserve this only for the highest-sensitivity flows rather than applying it network-wide.
- Recommendation: use ESP (tunnel mode, AES-GCM) as the default for all inter-branch and remote-access traffic — it delivers both confidentiality and integrity in one pass — and use AH only for niche, non-NATed control-plane authentication, giving the best balance of security and performance.

2. An organization faces frequent key management issues in its IPSec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
- B. Design an automated key management mechanism (e.g., IKE-based)
- C. Propose a strategy for key renewal and revocation
- D. Evaluate scalability and fault tolerance

Automated Key Management for IPSec SAs

Frequent key mismatches and expirations point to manual or poorly automated Security Association (SA) handling. The fix is a standards-based, automated key-management framework built around IKE.

A. Analysis of current SA lifecycle issues

- Static / manually configured pre-shared keys are common causes of mismatch — any change on one gateway that isn't mirrored exactly on the peer instantly breaks the SA.
- SAs have finite lifetimes (time-based and/or byte-based); if rekeying is not automated, the SA simply expires and traffic drops until an administrator intervenes.
- No centralized visibility: each gateway pair tracks its own SA state, so there is no enterprise-wide view of which keys are near expiry across dozens of branch tunnels.
- Lack of revocation process: a compromised key or a decommissioned branch may continue to have valid SAs/certificates because there is no systematic revocation trigger.

B. Automated key management mechanism (IKE-based)

- Deploy IKEv2 (RFC 7296) at every gateway to negotiate and automatically rekey both the IKE SA and the child (IPSec) SAs before expiry — removing manual key entry entirely.
- Use certificate-based authentication (X.509) issued by an internal enterprise PKI/CA instead of pre-shared keys, so each gateway proves identity cryptographically and keys are derived per-session via Diffie–Hellman (ECDHE) rather than reused static secrets.
- Centralize policy and monitoring with a Security Association/Key management server (e.g., a network-wide IKE/PKI management platform or SDN-based orchestrator) that pushes consistent IKE policy (ciphers, DH groups, lifetimes) to all branch gateways so no branch can drift out of sync.
- Configure automatic rekeying thresholds (e.g., rekey at 90% of the SA's time/byte lifetime) so a fresh SA is negotiated seamlessly before the old one expires, avoiding any traffic interruption.

C. Strategy for key renewal and revocation

- Renewal: IKEv2's built-in rekey exchange (CREATE_CHILD_SA) automatically generates new keying material ahead of expiry using Perfect Forward Secrecy (fresh DH exchange), so a compromise of one key does not expose past or future traffic.
- Certificate renewal: automate issuance via a protocol such as EST/SCEP against the internal CA with a defined validity window (e.g., 90 days) and auto-renewal 30 days before expiry.
- Revocation: maintain a Certificate Revocation List (CRL) or use OCSP so that a compromised branch gateway's certificate can be revoked immediately; gateways should check OCSP/CRL status before establishing or renewing any SA.
- Emergency revocation procedure: a documented runbook to revoke certificates and force-terminate active SAs for a specific branch within minutes of a suspected compromise, with automatic alerting to the security operations team.

D. Scalability and fault tolerance evaluation

- Certificate + IKEv2 based automation scales far better than pre-shared keys, because adding a new branch only requires issuing it a certificate from the central CA — no manual key distribution to every existing peer.
- A centralized PKI/policy server is a single point of failure if not made redundant; deploy CA and OCSP responders in an active-active or active-passive cluster across data centers to avoid an outage blocking new SA negotiation.
- Because IKEv2 negotiates SAs independently per tunnel, failure of the central management server does not immediately tear down existing SAs — only new negotiations/renewals are affected until it is restored, giving graceful degradation.
- Dead Peer Detection (DPD) and redundant gateway pairs (VRRP/HA pairs) at each branch improve fault tolerance so a gateway failure fails over without manual SA reconfiguration.

3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
- B. Analyze key management and trust models
- C. Recommend a solution with justification

PGP vs S/MIME for a Financial Services Company

The organization must secure sensitive transaction-related email. The choice between PGP and S/MIME depends on trust model, key infrastructure, and how well each integrates into an enterprise environment.

A. PGP vs S/MIME in real-world deployment

PGP: Uses a decentralized "Web of Trust" model; keys are generated and exchanged by individual users, often manually or via public key servers. It is popular among developers, security researchers, and privacy-focused individuals but is harder to manage at enterprise scale because there is no central authority validating identities.

S/MIME: Uses X.509 certificates issued by a trusted Certificate Authority (CA), and is natively built into virtually all enterprise mail clients (Outlook, Apple Mail, Exchange, Gmail via G Suite). This makes it far easier to roll out organization-wide without every employee manually installing extra software.

B. Key management and trust models

- PGP's Web of Trust relies on peer endorsement (users signing each other's keys); this is flexible but does not scale cleanly to thousands of employees and external banking partners, and there is no formal revocation authority — a lost key relies on the user publishing a revocation certificate themselves.
- S/MIME's hierarchical PKI (CA → intermediate CA → end-entity certificate) provides centralized issuance, renewal, and revocation (CRL/OCSP), matching how financial institutions already manage TLS certificates and regulatory identity requirements.
- For a financial company that must satisfy audit and compliance requirements (e.g., proving who could decrypt/sign a message and when), the CA-backed, auditable trust chain of S/MIME is a much closer fit than PGP's informal trust web.

C. Recommendation with justification

S/MIME is recommended for this financial services company.

- Native integration with Outlook/Exchange means no extra client software, reducing user training and support overhead.
- Centralized CA issuance aligns with existing corporate PKI used for TLS and employee smart cards/tokens, and satisfies audit trails required by financial regulators.
- Enterprise-grade revocation (CRL/OCSP) allows immediate response if an employee's certificate/key is compromised — critical for transaction-related correspondence.
- PGP may still be kept as a secondary option for secure communication with external partners/researchers who specifically require it, but it should not be the primary internal standard.

D. High-level implementation workflow

- 1) Stand up (or extend) an internal enterprise CA / use a commercial CA that issues S/MIME certificates.
- 2) Enroll every employee mailbox with an individual S/MIME certificate (auto-enrollment via Active Directory Certificate Services or similar), including private key protection via hardware tokens/TPM for high-privilege staff.
- 3) Configure mail clients/Exchange policies to sign all outgoing email by default and encrypt when the recipient's certificate is available.
- 4) Publish/exchange certificates with key business partners (banks, clearing houses) via a shared directory or certificate exchange process.

- 5) Implement monitoring for certificate expiry, automatic renewal reminders, and an incident-response revocation procedure.
- 6) Train staff on verifying signature validity and recognizing certificate warnings, and periodically audit compliance.

D. Design a high-level implementation workflow

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

- A. Identify limitations of existing filtering techniques
- B. Analyze email headers for spoofing indicators
- C. Design an improved detection model (rule-based or ML-based)
- D. Evaluate effectiveness and false positive handling

Advanced Spam and Phishing Detection

Basic filters are failing to stop phishing/spam. The fix combines header-level spoofing analysis with a smarter, layered detection model.

A. Limitations of existing filtering techniques

- Simple keyword/blacklist filters are easily evaded by attackers using misspellings, image-based text, URL shorteners, or newly registered domains not yet blacklisted.
- Basic filters often do not validate sender authenticity (SPF/DKIM/DMARC), so spoofed "From" addresses that impersonate executives or partners (business email compromise) slip through.
- Static rule sets cannot adapt to fast-evolving phishing campaigns and generate high false-negative rates against zero-day phishing templates.
- Lack of content/context analysis (urgency language, mismatched reply-to addresses, look-alike domains) means well-crafted social-engineering emails pass basic checks.

B. Analyzing email headers for spoofing indicators

- Check SPF (Sender Policy Framework) result: does the sending server's IP match the domain's authorized senders?
- Check DKIM (DomainKeys Identified Mail) signature validity: has the message body/headers been altered in transit, and does the signing domain match the claimed sender?

- Check DMARC alignment: do the From-domain, SPF-domain, and DKIM-domain align, and does the domain's DMARC policy request rejection/quarantine on failure?
- Inspect Received headers for routing anomalies (unexpected relay hops, mismatched reverse-DNS) and compare Reply-To / Return-Path against the visible From address for mismatches — a classic spoofing signal.

C. Improved detection model design

- Layer 1 – Authentication gate (rule-based): automatically quarantine/flag any mail failing SPF+DKIM+DMARC alignment, closing the most common spoofing vector immediately.
- Layer 2 – Content/ML classification: a machine-learning model (e.g., gradient-boosted trees or a fine-tuned transformer) trained on labeled phishing/legitimate corpora, using features such as urgency/pressure language, mismatched link-text vs actual URL, presence of credential-harvesting form patterns, sender-domain age, and attachment type/macro presence.
- Layer 3 – Behavioral/reputation signals: sender-domain reputation, historical volume from that IP, and whether the recipient has corresponded with this sender before (first-contact + financial-request emails scored higher risk).
- Combine layers in a scoring pipeline: authentication failures contribute a heavy weight, ML content score adds a probability, and behavioral anomalies add a bonus — final composite score routes mail to "deliver / warn-banner / quarantine / block."

D. Effectiveness and false-positive handling

- Evaluate using precision/recall and F1-score on a held-out labeled test set, plus real-world false-positive rate (legitimate mail wrongly blocked) which is the most business-sensitive metric for a company handling client communication.
- Use a tiered response rather than hard blocking: low-confidence flags get a warning banner ("external sender", "link may be unsafe") instead of outright deletion, reducing the cost of false positives.
- Maintain a feedback loop where users can report false positives/negatives, feeding back into periodic model retraining to track evolving phishing tactics.
- Continuously monitor DMARC aggregate/forensic reports (rua/ruf) to tune SPF/DKIM policy strictness over time without breaking legitimate mail flows (e.g., partners sending on the company's behalf).

5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

- A. Identify potential certificate-related vulnerabilities
- B. Analyze trust chain and validation process

C. Propose secure certificate storage and management practices

D. Recommend improvements for user awareness and system configuration

Certificate Handling Vulnerabilities in S/MIME

An audit found weaknesses in S/MIME certificate handling. The diagnosis covers certificate-level vulnerabilities, trust-chain validation, and recommended best practices.

A. Potential certificate-related vulnerabilities

- Expired or revoked certificates still being trusted because clients are not configured to check CRL/OCSP status in real time.
- Private keys stored insecurely (unencrypted on disk, shared mailboxes, or exported without a passphrase), allowing an attacker to decrypt/forgo signed mail if the endpoint is compromised.
- Self-signed or improperly issued certificates being accepted without proper chain validation, opening the door to man-in-the-middle impersonation.
- Weak or deprecated cryptographic algorithms (e.g., SHA-1 signatures, RSA-1024 keys) still permitted by legacy certificates, making forgery computationally feasible.
- No certificate pinning or consistent identity binding, so a user's certificate can be silently swapped by an attacker who obtains a fraudulently issued cert for the same email address from a less rigorous CA.

B. Trust chain and validation process analysis

- Every S/MIME certificate must chain up through intermediate CA(s) to a trusted root; the audit should verify mail clients hold an up-to-date, minimal trusted-root store rather than trusting an overly broad default list.
- Validation must include: signature verification at each link in the chain, expiry-date checks at every level (leaf, intermediate, root), and revocation checks (CRL or OCSP, ideally OCSP stapling for performance) — the audit likely found one or more of these steps skipped or misconfigured.
- Name/identity binding must be checked — the certificate's Subject/SAN email address must exactly match the sender's From address, otherwise a validly-chained but wrong-identity certificate could be misused.

C. Secure certificate storage and management practices

- Store private keys in hardware security modules (HSMs) or smart cards/TPM-backed key stores rather than plain software key stores, especially for high-value executives handling financial approvals.
- Enforce strong passphrase protection and automatic key-store locking on endpoint compromise or device loss.
- Adopt short validity periods with automated renewal (as in Q3), and enforce OCSP/CRL checking as mandatory (not optional) in mail-client and gateway configuration.
- Deprecate weak algorithms organization-wide — mandate SHA-256+ signatures and RSA-2048/ECC-P256 minimum key strength, retiring any legacy certificates that don't meet this bar.

- Maintain a centralized certificate inventory/management platform to track issuance, expiry, and revocation status across all employees, preventing "orphaned" or forgotten certificates.

D. Recommendations for user awareness and configuration

- Train employees to recognize and never ignore certificate-warning dialogs (expired, untrusted, name-mismatch) rather than clicking through them.
- Educate staff on verifying the presence of a valid digital signature icon before trusting an email's authenticity, especially for messages requesting fund transfers or credential changes.
- Harden default mail-client configuration company-wide (enforce OCSP checking, disable weak ciphers, require encryption for messages tagged "confidential") via centrally pushed policy rather than relying on individual user settings.

Run periodic internal phishing/certificate-spoofing simulations and re-audit certificate configurations on a recurring schedule (e.g., quarterly) to catch drift before it becomes an incident.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis
Professionalism	5%	Highly professional, well-documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation